

CSIT302 Cybersecurity

Day 4-1 – Digital Forensics

Subject Coordinators: Dr Partha Sarathi Roy
School of Computing and Information Technology

Digital Forensics

- Forensics science is the application of scientific methods to collect, preserve and analyse evidence related to legal cases.
- Digital forensics is the application of computer science and investigative procedures for a legal purpose involving the analysis of digital evidence.
- The field of digital forensics can also encompass items such as research and incident response.
- Standards:
 - NIST SP 800-86 Guide to Integrating Forensic Techniques into Incident Response;
 - ISO/IEC 27037 Information technology - Security techniques : Guidelines for identification, collection, acquisition and preservation of digital evidence

Digital Forensics

- In NIST 800-86
 - digital forensics is the application of science to the identification, collection, examination, and analysis of data while preserving the integrity of the information and maintaining a strict chain of custody for the data.
- Investigating digital devices include:
 - collecting data securely
 - examining suspect data to determine details such as origin and content
 - presenting digital information to courts
 - applying laws to digital device practice

Digital Forensics

- In general,
 - digital forensics is used to investigate data that can be retrieved from a computer's hard drive or other media. The information retrieved might already be on the drive, but it might not be easy to find or decipher.
 - network forensics yields information about how attackers gain access to a network along with files they might have copied, examined, or tampered with.
 - ✓ The examiners use log file to find out user login time, method and location , URLs accessed.
 - ✓ To find what tracks or files are left behind on a victim's computer and what changes are made.

Why do we need digital forensics?

- Besides the needs of criminal investigations and computer security incident handling, forensics tools and techniques are also useful for many other tasks, such as:
 - Operational Troubleshooting
 - Log Monitoring
 - Data Recovery
 - Data Acquisition
 - Due Diligence/Regulatory Compliance

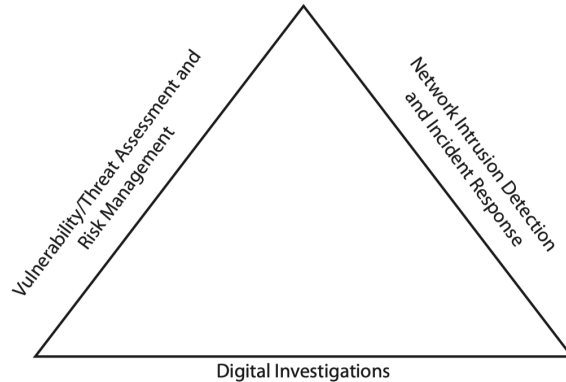
Data Forensics VS Data Recovery

- The task of recovering data that users have hidden or deleted.
- It is unknown what contents will be found.
- The goal is to ensure that the recovered data is valid so that it can be used as evidence.

- Retrieve information deleted by mistake or lost during an accident
- Typically, you know what you are looking for.

Investigations Triad for Computer Security

- Forensics investigators often work as part of a team to secure an organization's computers and networks.

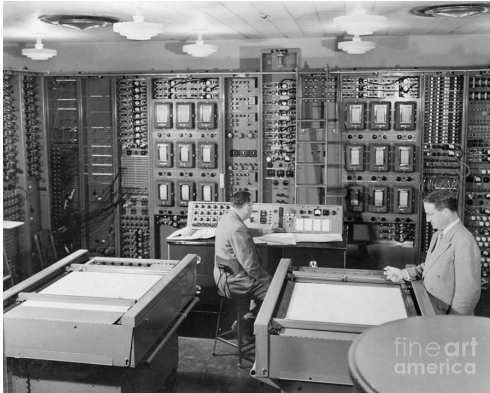


Investigations Triad for Computer Security

- Investigation triad is made up of the following functions:
 - Vulnerability/threat assessment and risk management
 - Test and verify the **integrity** of stand-alone workstations and network servers, which covers the physical security of systems and the security of operating systems (OSs) and applications.
 - Do the penetration test for vulnerabilities of OSs and applications and conduct authorized test
 - Network intrusion detection and incident response
 - Detect intruder attacks and response to the attack detected
 - Collects evidence for litigation against intruder
 - Digital investigations
 - Manage investigations and conducts forensics analysis of systems suspected of containing evidence related to an incident or a crime.

A Brief History of Digital Forensics

- By the 1970s, electronic crimes were increasing especially in the financial sector.



In 1970s, period of mainframe computers

- people have no idea on how to collect computer evidence



Figure 1-3 An 8088 computer

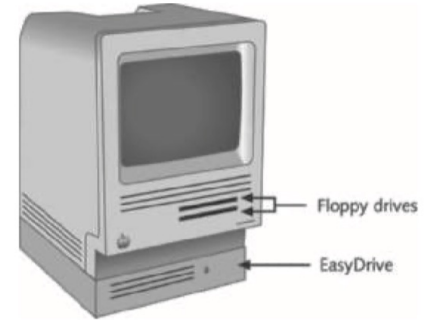


Figure 1-4 A Mac SE with an external EasyDrive hard disk

In 1980s,

- only simple forensics tools, most generated by government agencies.
- Xtree Gold appeared in mid-1980s. which recognized file types and retrieved lost or deleted files.
- Soon, Norton DiskEdit appeared and became the preferred tool for finding and recovering deleted files.

A Brief History of Digital Forensics

- By the early 1990s, the International Association of Computer Investigative Specialists (IACIS) introduced training on software for digital forensics examinations.
- The U.S. Internal Revenue Service (IRS) created search-warrant programs.
- ASR Data created Expert Witness for Macintosh, the first commercial GUI software, which can recover deleted files and fragments of deleted files.
- More digital forensics tools are developed as computer technology evolving, including
 - ILook is currently maintained by the IRS Criminal Investigation Division can analyze and read special files that are copies of a disk.
 - AccessData Forensic Toolkit (FTK) is a popular commercial product in the law enforcement and civilian markets
 - ...

Developing Digital Forensics Resources

- To be a successful digital forensic investigator, you need to
 - Develop and maintain contact with computing, network, and investigative professionals.
 - Join computer user groups in both the public and private sectors
 - ✓ Example: **Computer Technology Investigators Network (CTIN)** meets to discuss problems with digital forensics examiners encounter
 - Consult outside experts

Preparing for Digital Investigations

- Digital Investigations fall into two categories:
 - public-sector investigations
 - private-sector investigations

Government agencies
Article 8 in the Charter of Rights of Canada
U.S. Fourth Amendment search
and seizure rules

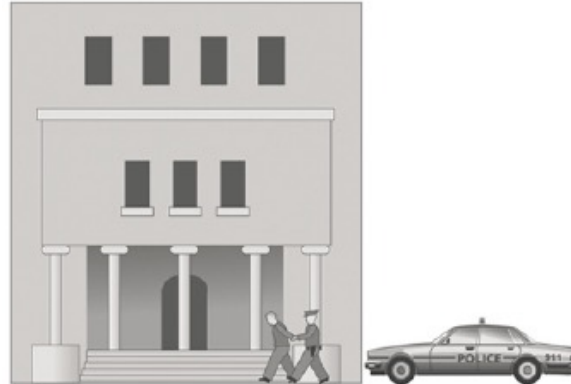


Figure 1-5 Public-sector and private-sector investigations
©Cengage Learning®

Public-sector Investigations

- Public-sector investigations involve government agencies responsible for criminal investigations and prosecution.
- The examiner must understand laws on computer-related crimes, including:
 - Standard legal process
 - Guidelines on search and seizure
 - How to build a criminal case.
- To determine whether there was a computer crime, an investigator asks question like
 - What was the tool used to commit the crime?
 - Was it a simple trespass?
 - Was it a theft or vandalism?
 - Did the perpetrator infringe on someone else's rights by cyberstalking or e-mail harassment?

Public-sector Investigations

- When conducting a computer investigation for potential criminal violations of the law, you should follow the legal processes, depending on
 - Local custom
 - Legislative standards
 - Rules of evidence
- A criminal case follows three stages in general:
 - The complaint
 - The investigation
 - The prosecution

Private-sector Investigations

- Private-sector investigations focus more on policy violations, which involve private companies and lawyers who address company policy violations and litigation disputes.
 - Private-sector computer crimes can involve e-mail harassment, falsification of data, gender and age discrimination, embezzlement, sabotage, and industrial espionage, which involves selling sensitive or confidential company information to a competitor.
- When investigating for a private company, remember that business must continue with **minimal interruption** from your investigation.

Private-sector Investigations

- Businesses also strive to minimize or eliminate litigation, which is an expensive way to address criminal or civil issues.
- Business can use several measures to reduce the risk of litigation, including:
 - Publishing and maintaining policies that employees find easy to read and follow
 - Displaying warning banners
 - ✓ which informs end users that the organization reserves the right to inspect computer systems and network traffic at will.
- The displaying warning banners can be used to show the line of authority for an investigation, which can
 - show the user's expectation of privacy,
 - avoid the issue of authority to inspect.

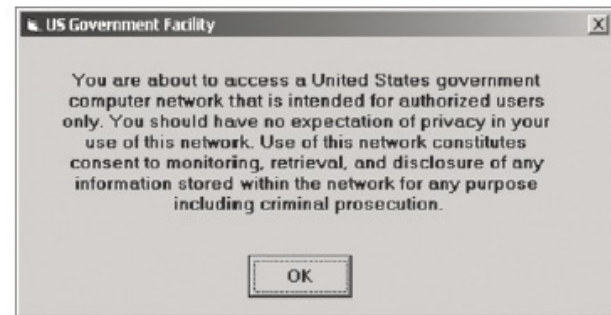


Figure 1-8 A sample warning banner
©Cengage Learning®

Private-sector Investigations

- Depending on the type of organization, the following text can be used in internal warning banners:
 - Access to this system and network is restricted.
 - Use of this system and network is for official business only.
 - Systems and networks are subject to monitoring at any time by the owner.
 - Using this system implies consent to monitoring by the owner.
 - Unauthorized or illegal users of this system or network will be subject to discipline or prosecution.
 - Users of this system agree that they have no expectation of privacy relating to all activity performed on this system.
- Some warnings for guest:
 - This system is the property of Company X.
 - This system is for authorized use only; unauthorized access is a violation of law and violators will be prosecuted.
 - All activity, software, network traffic, and communications are subject to monitoring.

Private-sector Investigations

- To prepare for a private-sector investigation, businesses are advised to specify an **authorized requester** who has the power to initiate investigation.
- Examples of groups with this authority in a private-sector environment include following:
 - Corporate security investigations
 - Corporate ethics office
 - Corporate equal employment opportunity office
 - Internal auditing
 - The general counsel or legal department

Private-sector Investigations

- During private investigations, you search for evidence to support allegations of violations of a company's rules or an attack on its assets.
- Three types of situations are common in private-sector environments:
 - Abuse or misuse of computing assets
 - E-mail abuse
 - Internet abuse
- A private-sector investigator's job is to minimize risk to the company.

Private-sector Investigations

- Many company policies distinguish between personal and company computer property.
- However, the distinction is difficult with the popularity of portable devices, like smartphones, personal notebooks, and tablet computers.
- In today's bring your own device (BYOD) environment, more companies are forced to address the issue of personal devices accessing the company network.
 - Some companies simply state that if you connect a personal device to the business network, it falls under the same rules as company property.
 - BYOD is a major challenge in company security, digital investigations, and compliance with regulations, including company policies.

Maintaining Professional Conduct

- Your professional conduct as a digital investigator is critical because it determines your credibility.
- Professional conduct includes
 - ethics,
 - morals,
 - Standards of behavior.
- As a professional, you must exhibit the highest level of professional behavior by:
 - maintaining **objectivity and confidentiality** during an investigation
 - maintaining an investigation's **credibility** by maintaining confidentiality
- Investigators should also attend training to stay current with the latest technical changes in computer hardware and software, networking, and forensic tools

Preparing a Digital Forensics Investigation

- The role of a digital forensics professional is to gather evidence to prove a suspect committed a crime or policy violation.
- If the evidence suggests that a crime or policy violation has been committed, an investigation process begins.
- An investigation process must follow an accept procedure.
- Next, we will talk the typical steps of preparing two types of forensics investigation,
 - preparing for the investigation of a computer crime
 - preparing for the investigation of a company policy violation

Preparing A Computer Crime Investigation

- Computers, smartphones, and other devices can contain information that helps law enforcement officers determine
 - the chain of events leading to a crime;
 - information providing evidence that's more likely to lead to a conviction.
- Law enforcement officers should follow proper procedure when acquiring the evidence
 - Digital evidence can be easily altered by an overeager investigator
- Refer to some documents
 - The U.S. DOJ has a document that reviews the correct acquisition of electronic evidence, "Prosecuting Computer Crimes"
(www.justice.gov/criminal/cybercrime/docs/ssmanual2009.pdf, 2009).
- Identify the challenges may faced during the investigation

Preparing A Company Policy Violation Investigation

- The preparation of a forensics investigation of a company policy violation should consist of the following aspects:
 - Taking a Systematic Approach
 - Accessing the Case
 - Planning Your Investigation
 - Securing Your Evidence

Preparing A Company Policy Violation Investigation: Taking a Systematic Approach

- The **preparation for an investigation** can apply standard systems analysis steps, including:
 - Make an initial assessment about the type of case you're investigating
 - Determine a preliminary design or approach to the case
 - Create a detailed checklist
 - Determine the resources you need
 - Obtain and copy an evidence drive
 - Identify the risks
 - Mitigate or minimize the risks

Taking a Systematic Approach

- The **preparation for an investigation** can apply standard systems analysis steps, including: cont'd)
 - Test the design
 - Analyze and recover the digital evidence
 - Investigate the data you recover
 - Complete the case report
 - Critique the case
- For all computing investigations, you must be prepared for the unexpected, so you should always have a **contingency plan** for the investigation. A contingency plan can consist of anything to help you complete the investigation, from alternative software and hardware tools to other methods of approaching the investigation.

Preparing A Company Policy Violation Investigation: Accessing the case

- To determine the type of case you are investigating, you should take into consideration of the following aspects
 - the nature of the case,
 - the type of evidence available,
 - the location of evidence.

Preparing A Company Policy Violation Investigation: Planning Your Investigation

- After identifying the type of the case, now you can plan your investigation.
- A basic investigation plan should include the following activities:
 - Acquire the evidence
 - Complete an evidence form and establish a chain of custody
 - Transport the evidence to a computer forensics lab
 - Secure evidence in an **approved secure container**
 - Prepare your **forensics workstation**
 - Retrieve the evidence from the secure container
 - Make a forensic copy of the evidence
 - Return the evidence to the secure container
 - Process the copied evidence with computer forensics tools

Planning Your Investigation

- An **evidence custody form**, also called a **chain-of-evidence form**, which helps you document what has and has not been done with the original evidence and forensic copies of the evidence.
 - You can create an evidence custody form to fit your environment.
 - This form should be easy to read and use.
 - It can contain information for one or several pieces of evidence.
 - Consider creating a single-evidence form (which lists each piece of evidence on a separate page) and a multi-evidence form depending on the administrative needs of your investigation.

Multi- and Single- Evidence Forms

[illegible]

Figure 1-10 A sample multi-evidence form used in a private-sector environment
©Cengage Learning®

[illegible]

Figure 1-11 A single-evidence form
©Cengage Learning®

Planning Your Investigation

- An evidence custody form usually contains the following information:
 - Case number
 - Investigating organization
 - Investigator
 - Nature of case
 - Location evidence was obtained
 - Description of evidence
 - Vendor name
 - Model number or serial number
 - Evidence recovered by—The name of the investigator who recovered the evidence.
 - Date and time
 - Evidence placed in locker
 - Item #/Evidence processed by/Disposition of evidence/Date/Time
 - Page number

Preparing A Company Policy Violation Investigation : Securing Your Evidence

- To secure your evidence
 - Use evidence bags to secure and catalog the evidence
 - Use computer safe products when collecting computer evidence
 - ✓ Antistatic bags
 - ✓ Antistatic pads
 - Use well padded containers
 - Use evidence tape to seal all openings
 - ✓ CD drive bays
 - ✓ Insertion slots for power supply electrical cords and USB cables
- Write your initials on tape to prove that evidence has not been tampered with
- Consider computer specific temperature and humidity ranges
 - Make sure you have a safe environment for transporting and storing it until a secure evidence container is available

Understanding Data Recovery Workstations and Software

- Investigations are conducted on a digital forensics lab (or data-recovery lab)
 - In data recovery, the customer or your company just wants the data back
- Setup a specifically configured PC known as a forensic workstation
 - a computer loaded with additional bays and forensics software.
- To avoid altering the evidence use:
 - Write-blockers devices
 - ✓ Enable you to boot to Windows without writing data to the evidence drive

Understanding Data Recovery Workstations and Software

- Some requirements for setting up your workstation
 - A workstation running Windows XP or later
 - A write-blocker device
 - Digital forensics acquisition tool
 - Digital forensics analysis tool
 - A target drive to receive the source or suspect disk data
 - Spare PATA or SATA ports
 - USB ports
- Analysis software can be installed for forensics, including:
 - ProDiscover, EnCase, FTK, or X-Ways Forensics; an office suite, such as LibreOffice; and a graphics viewer, such as IrfanView.

What we have done

- An investigation process
 - Create a plan for investigation
 - Setup the forensic workstation and install the necessary forensics software
 - Conduct an investigation

Conducting an Investigation

- Generally, Conducting an Investigation consists of the following steps:
 - Gathering the Evidence
 - Acquiring an Image of Evidence Media
 - ✓ Bit-stream copies
 - ✓ ProDiscover
 - Analyzing Your Digital Evidence
 - ✓ ProDiscover
 - Completing the Case
 - Critiquing the Case

Different Sources for Data Collection

- When conducting digital forensics, data can be collected from different sources, including:
 - using data from data files
 - using data from operating systems
 - using data from network traffic
 - Using data from applications

Case Study: Web Browser Forensics

- What Information can we collect from a web browser?



Reference & Recommended Reading

- **Guide to Computer Forensics and Investigations: Processing Digital Evidence** (Fifth Edition). Bill Nelson, Amelia Phillips and Christopher Steuart. Chapter 1.